Compliance Annotation

VitalTrack Wellness App

Framework: HIPAA + SOC 2 | Compliance Level: Significant Non-Compliance / High Risk

---

HIPAA Privacy & Breach Notification Rules

Finding 1: [VIOLATION] Marketing & Sale of PHI Without Authorization (45 CFR 164.508) VitalTrack shares user names and health profile summaries with "wellness product partners" to provide "personalised product recommendations". This constitutes marketing as defined by HIPAA, and if VitalTrack receives financial remuneration for this sharing, it qualifies as a "Sale of PHI". Both activities strictly require a signed, written authorization from the patient, which is not mentioned or obtained in the current policy. **References:** 45 CFR 164.501, 45 CFR 164.508(a)(3-4)

Finding 2: [VIOLATION] Unlawful Data Sharing with Pharmaceutical Companies (45 CFR 164.512(i)) The platform shares health trend data with pharmaceutical companies for "market analysis" and "market research". Under HIPAA, research disclosures without patient authorization are only permitted under specific IRB/Privacy Board waivers or as a "Limited Data Set" with a Data Use Agreement, neither of which are described. Market analysis for commercial entities generally falls outside the scope of permitted research disclosures without explicit authorization. **References:** 45 CFR 164.508, 45 CFR 164.512(i)

Finding 3: [VIOLATION] Absence of Designated Privacy Officer (45 CFR 164.520(b)(1)(vii)) The notice fails to identify a specific individual or office to serve as the Privacy Officer. HIPAA mandates that the Notice of Privacy Practices (NPP) must include the name (or title) and telephone number of a person or office to contact for further information or to file a complaint. **References:** 45 CFR 164.520(b)(1)(vii)

Finding 4: [VIOLATION] Deficiency in Breach Notification Specificity (45 CFR 164.404) While VitalTrack commits to complying with "notification requirements," the policy fails to mention the mandatory 60-day notification window for breaches of unsecured PHI. Furthermore, it does not describe the required content of the notification, such as the types of PHI involved or the steps individuals should take to protect themselves. **References:** 45 CFR 164.404(c)

Finding 5: [VIOLATION] Omission of Mandatory Patient Rights (45 CFR 164.522 - 164.528) The policy directs users to their healthcare providers to exercise rights but fails to acknowledge these rights for data held "independently". Specifically, it omits the right to request confidential communications, the right to a paper copy of the notice, and the mandatory right to restrict disclosures to health plans for services paid in full out-of-pocket. **References:** 45 CFR 164.522, 164.524, 164.528

Finding 6: [CONCERN] Minimum Necessary Standard in AI Processing (45 CFR 164.502(b)) The app uses "proprietary AI algorithms" to analyze health metrics and activity patterns. There is no mention of the "Minimum Necessary" standard being applied to these internal processing activities, nor is there a description of how PHI is protected during the training of these algorithms. **References:** 45 CFR 164.502(b), 45 CFR 164.514(d)

Finding 7: [VIOLATION] Invalid Acceptance of Material Changes (45 CFR 164.520) VitalTrack states that "Continued use... constitutes your acceptance" of updated practices. For a covered entity or business associate, material changes to privacy practices that affect the legal basis of processing or patient rights cannot be accepted through passive "continued use"; they must be clearly communicated and, in some cases, require new authorizations. **References:** 45 CFR 164.520(b)(1)(v), 45 CFR 164.508

SOC 2 Trust Services Criteria

Finding 8: [VIOLATION] Governance & Security Oversight Gaps (CC1) There is no mention of a Chief Information Security Officer (CISO), a formal security program, or Board-level oversight of security risks. The absence of a structured governance framework fails the CC1.1 and CC1.2 criteria regarding the establishment of security objectives and accountability. **References:** SOC 2 CC1.1, CC1.2

Finding 9: [VIOLATION] Absence of Formal Risk Assessment Process (CC3) VitalTrack mentions "periodic security reviews" but provides no evidence of a formal, annual risk assessment or a HIPAA-mandated Security Risk Analysis (SRA). CC3 requires the identification and assessment of risks to the achievement of security and privacy objectives, including fraud risk. **References:** SOC 2 CC3.1, 45 CFR 164.308(a)(1)

Finding 10: [VIOLATION] Logical Access & Multi-Factor Authentication (MFA) Gap (CC6) The policy notes access via SSH keys and VPN for engineering personnel but fails to mention Multi-Factor Authentication (MFA) for either administrative or regular user accounts. Failing to enforce MFA for a platform managing PHI for 2 million users is a significant security deficiency. **References:** SOC 2 CC6.1

Finding 11: [VIOLATION] Lack of Formal Incident Response & Testing (CC7) While the policy mentions a commitment to comply with breach laws, it does not describe a documented Incident Response Plan (IRP) or a program for semi-annual tabletop testing. Operationally effective incident response requires predefined procedures for detection, containment, and recovery. **References:** SOC 2 CC7.3

Finding 12: [VIOLATION] Incomplete Change Management (CC8) "Security testing (SAST and DAST)" is mentioned before major releases, but there is no description of a formal change management process involving peer reviews, staging environment tests, or a Change Advisory Board (CAB). **References:** SOC 2 CC8.1

Finding 13: [VIOLATION] Availability & Disaster Recovery (DR) Deficiencies (A1) The policy notes that "backup copies may persist for up to 90 days" but provides no Recovery Time Objective (RTO), Recovery Point Objective (RPO), or evidence of regular disaster recovery failover testing. There is no mention of multi-region redundancy to ensure platform availability. **References:** SOC 2 A1.2

Finding 14: [VIOLATION] Vendor Risk Management Gap (CC9) VitalTrack relies on wearable integrations (Apple, Fitbit, etc.) and wellness partners but does not describe a formal vendor risk assessment program, such as reviewing SOC 2 reports or conducting security questionnaires before engagement. **References:** SOC 2 CC9.2

Finding 15: [VIOLATION] Missing Workforce Security Training (CC1.4) There is no mention of mandatory annual security awareness training or specialized HIPAA training for employees who handle PHI. CC1.4 requires the organization to ensure that personnel are competent and aware of their security responsibilities. **References:** SOC 2 CC1.4, 45 CFR 164.308(a)(5)